COMPTE RENDU

TP 1-2_Chapitre I : Introduction à la Threat Intelligence et recherche de vulnérabilités

Introduction

La Threat Intelligence (ou renseignement sur les menaces) est un ensemble de données, d'analyses et d'informations qui permettent de comprendre les cybermenaces pour mieux les anticiper, les détecter et s'en protéger. En clair, c'est le fait de collecter et analyser des informations sur les attaques informatiques (pirates, virus, vulnérabilités, etc,…).

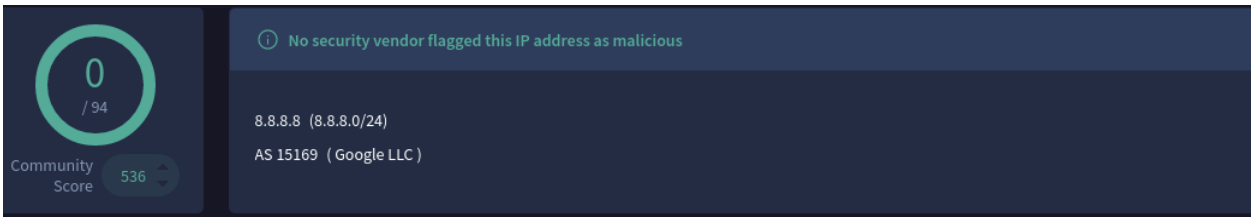
Il a pour rôle de :

- Anticiper les attaques : voir venir les menaces avant qu'elles ne touchent un système ;
- Détecter plus rapidement les intrusions ;
- Réagir plus efficacement : réponse aux incidents ;
- Renforcer la sécurité globale ;
- Aider les décisions en cybersécurité : prioriser les risques ; choisir les bons outils de protection.

2-Analyse de l'adresse IP

VirusTotal est une plateforme en ligne de cybersécurité qui permet d'analyser des fichiers, des liens, des adresses, des domaines.

Dans notre cas, nous avons effectué l'analyse de l'adresse 8.8.8.8 qui est une adresse publique, adresse de google.



Nous avons obtenu un score de 536 qui est un score de réputation/ activité réseau basé sur l'observation de l'adresse sur internet. Ce score n'est pas un score de danger ou de virus.

3-Analyse des services

La commande **nmap -sV 192.168.56.10** : détecte les ports ouverts et les versions des services de la machine cible (192.168.56.10).

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo nmap -sV 192.168.56.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-15 19:04 WAT
Nmap scan report for 192.168.56.10
Host is up (0.00032s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol
2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 00:0C:29:E4:3F:C4 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.42 seconds
┌──(laurasimo㉿laura)-[~]
└─$
```

Comme ports ouverts détectés, nous avons : port 22 (SSH), port 80 (HTTP).

D'après l'analyse de la figure ci-dessus, le service SSH est de version 8.2 qui est une version assez récente (2020), ne possède pas de faille critique.

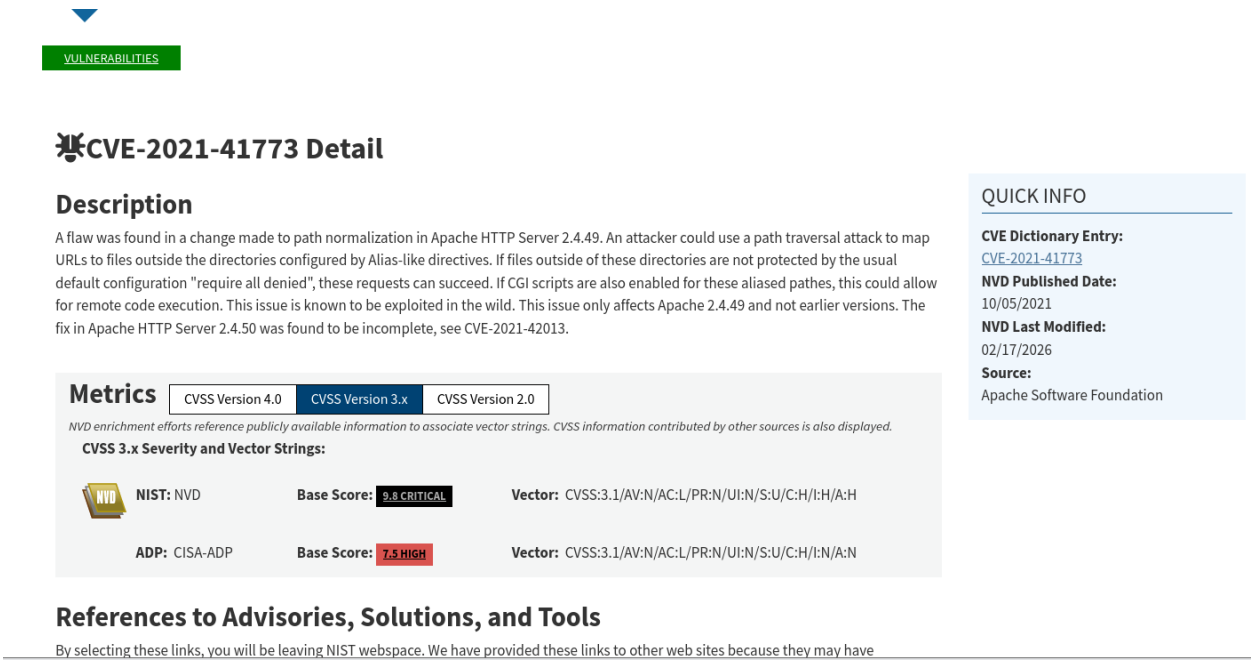
```
┌──(laurasimo㉿laura)-[~]
└─$ sudo searchsploit apache
---------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                        |  Path
---------------------------------------------------------------------- ---------------------------------
Apache (Windows x86) - Chunked Encoding (Metasploi                    | windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote C                    | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Exec                    | php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Denial of Se                    | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial of Ser                    | linux/dos/371.c
Apache - Denial of Service                                            | linux/dos/18221.c
Apache - httpOnly Cookie Disclosure                                   | multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial of Servi                    | multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-cgi' D                    | cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclosure                        | multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Server 1.                    | multiple/dos/19536.txt
Apache 1.2 - Denial of Service                                        | multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Header D                    | windows/dos/20272.pl
Apache 1.3 + PHP 3 - File Disclosure                                  | multiple/remote/20466.txt
Apache 1.3 - Artificially Long Slash Path Director                    | multiple/remote/20692.pl
Apache 1.3 - Artificially Long Slash Path Director                    | multiple/remote/20693.c
Apache 1.3 - Artificially Long Slash Path Director                    | multiple/remote/20694.pl
Apache 1.3 - Artificially Long Slash Path Director                    | multiple/remote/20695.pl
Apache 1.3 - Directory Index Disclosure                               | multiple/remote/21002.txt
Apache 1.3.12 - WebDAV Directory Listings                             | linux/remote/20210.txt
Apache 1.3.14 - Mac File Protection Bypass                            | osx/remote/20911.txt
Apache 1.3.20 (Win32) - 'PHP.exe' Remote File Disc                    | windows/remote/21204.txt
Apache 1.3.31 mod_include - Local Buffer Overflow                     | linux/local/587.c
Apache 1.3.34/1.3.33 (Ubuntu / Debian) - CGI TTY P                    | linux/local/3384.c
Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Reques                    | linux/remote/28424.txt
Apache 1.3.6/1.3.9/1.3.11/1.3.12/1.3.20 - Root Dir                    | windows/remote/19975.pl
Apache 1.3.x + Tomcat 4.0.x/4.1.x mod_jk - Chunked                    | unix/dos/22068.pl
```

La commande **searchsploit apache** présente la liste des vulnérabilités connues (CVE/ exploits) liées à Apache.

La sortie de searchsploit révèle plusieurs catégories de vulnérabilités affectant Apache. Les exploits de type Remote Code Execution (RCE) sont les plus critiques car ils permettent à un attaquant d'exécuter du code arbitraire sur le serveur distant sans authentification préalable.

4-Etude d'une CVE

Une CVE est un identifiant unique attribué à une vulnérabilité informatique connue.



VULNERABILITIES

CVE-2021-41773 Detail

Description

A flaw was found in a change made to path normalization in Apache HTTP Server 2.4.49. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution. This issue is known to be exploited in the wild. This issue only affects Apache 2.4.49 and not earlier versions. The fix in Apache HTTP Server 2.4.50 was found to be incomplete, see CVE-2021-42013.

Metrics CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD	**Base Score:** 9.8 CRITICAL	**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
ADP: CISA-ADP	**Base Score:** 7.5 HIGH	**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have

QUICK INFO

CVE Dictionary Entry: CVE-2021-41773
NVD Published Date: 10/05/2021
NVD Last Modified: 02/17/2026
Source: Apache Software Foundation

La CVE-2021-41773 est une faille dans Apache http server. Elle permet de standariser la communication entre chercheurs, éditeurs et outils de cybersécurité.

CVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.58**. Elle est causée par une validation insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveurCVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.58**. Elle est causée par une validation

insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveur.

Impact

L'impact est double selon la configuration du serveur :

Divulgation d'information La vulnérabilité permet d'accéder à des fichiers sensibles en dehors du document root.

Exécution de code à distance Bien que le CVE-2021-41773 était qualifier de simple bug de divulgation d'informations, des chercheurs indépendants ont confirmé que la vulnérabilité peut être utilisée pour de l'exécution de code à distance.

Sur le plan des **triade CIA** :

- **Confidentialité** : compromise (accès à des fichiers privés)
- **Intégrité** : compromise si RCE possible (modification de fichiers)
- **Disponibilité** : compromise (risque de prise de contrôle totale du serveur)

Niveau de gravité

Le score CVSS de base est de 7.5 (HIGH), mais en présence du module mod_cgi activé, l'exploitation en RCE fait monter la criticité à 9.8 (CRITICAL). Cette vulnérabilité a été exploitée comme zero-day avant même la publication du patch officiel.

Exploitation possible

L'exploitation peut être réalisée manuellement via une requête curl ou avec Metasploit en utilisant les deux vecteurs mentionner plus dans la capture d’écran.

5-Utilisation avancée de searchsploit

Searchsploit dispose de plusieurs options avancées permettant d'affiner la recherche, d'inspecter le code source des exploits et de les copier dans le répertoire de travail. Nous présentons ici trois options essentielles pour un usage professionnel.

searchsploit -x <chemin>

L'option -x (eXamine) permet d'afficher directement dans le terminal le contenu du fichier d'exploit sans avoir à le copier au préalable. Elle ouvre le fichier en lecture seule dans un paginateur (less), ce qui permet d'analyser rapidement le code source, de comprendre le mécanisme d'exploitation et d'identifier les prérequis nécessaires.

Utilité : Très utile lors de la phase d'analyse pour comprendre un exploit avant de décider de l'utiliser. Permet de vérifier la compatibilité avec la cible (OS, version du service) et d'identifier les paramètres à adapter sans modifier le fichier original.

searchsploit -m <id>

L'option -m copie l'exploit sélectionné dans le répertoire de travail courant. Contrairement à -x qui affiche seulement, -m crée une copie locale modifiable du fichier.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo searchsploit -m 34
[sudo] password for laurasimo:
  Exploit: Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution
      URL: https://www.exploit-db.com/exploits/34
     Path: /usr/share/exploitdb/exploits/linux/remote/34.pl
    Codes: OSVDB-15391
 Verified: True
File Type: Perl script text executable
Copied to: /home/laurasimo/34.pl

┌──(laurasimo㉿laura)-[~]
└─$
```

searchsploit apache 2.4

Cette syntaxe de base permet de rechercher tous les exploits disponibles pour un service donné et une version spécifique.

6. Analyse globale de sécurité

6.1 Risques identifiés

L'analyse combinée du scan Nmap, de VirusTotal et de searchsploit permet d'identifier plusieurs risques :

- Risque de déni de service (DoS) : plusieurs exploits référencés permettent de saturer le service Apache et de le rendre indisponible, impactant la continuité d'activité.
- Risque de divulgation d'informations : des vulnérabilités d'Information Disclosure exposent la structure interne du serveur (répertoires, version, configuration), facilitant les attaques ultérieures.
- Risque lié aux services port.

6.2 Service le plus dangereux

Le service le plus dangereux identifié est Apache HTTP qui écoute sur le port 80 qui est un port ouvert.

6.3 Actions recommandées

- Mettre à jour immédiatement Apache et PHP vers les dernières versions stables afin d'éliminer les CVE connues.
- Désactiver les services non nécessaires pour réduire la surface d'attaque.
- Effectuer des audits de sécurité réguliers (pentest, scan de vulnérabilités) pour détecter les nouvelles failles avant qu'elles ne soient exploitées.

7-Lien aven l'entreprise

Un analyste SOC utilise la Threat Intelligence pour correler les logs internes avec des bases de données externes. Si une IP connue pour être malveillante tente de se connecter, le SOC peut automatiser son blocage.

Il peut anticiper une attaque en surveillant les nouvelles CVE avant qu'elles ne soient exploitées massivement.

Conclusion

Ce TP mous a permis de comprendre la reconnaissance Nmap, l'analyse de vulnérabilité (searchsploit/ CVE). En effet, une mencac peut être réelle avant même d'etre listée sur VirusToal. La maîtrise de la chaîne d'outils Nmap vers searchsploit vers recherche de CVE constitue le socle technique d'un analyste en sécurité offensive. Chaque outil joue un rôle précis : Nmap pour la

découverte, searchsploit pour la recherche d'exploits, et les bases CVE pour la qualification et la priorisation des risques.